

Plan de containment

Confinement de l'attaque MIRAGE — Cellule de crise AtlasGrid

Version complète : actions, décisions, pièces et suivi — situation au soir du jour 2

Ben Cheich Hamza Atouahri Malak El Hadri Safae
Kouji Mohammed Chamli Romyssaa Zekri Taha

Légende des statuts : **Fait** = réalisé et vérifié ; **En cours** = lancé ; **À faire** = décidé, pas lancé ; **À confirmer** = réalisé selon nos informations, à vérifier ; **Bloqué** = en attente d'une décision ou d'un tiers.

1. Objectif et principes

Le containment vise à **arrêter la progression de l'attaque** et à **couper l'attaquant de nos systèmes**, avant l'éradication et la reprise. Il s'appuie sur les preuves qualifiées : accès par le compte `svc_oasisnet` via le VPN (A-02), canal de commande depuis FIN-112 (A-09), neutralisation des sauvegardes (A-05), chiffrement de 23 serveurs (A-13).

- **Isoler plutôt qu'éteindre** : couper le réseau en laissant les machines sous tension préserve la mémoire vive pour l'enquête.
- **Préserver avant de supprimer** : chaque journal, règle ou compte est copié par le Forensic avant d'être modifié.
- **Protéger d'abord ce qui est vital** : OT, sauvegardes restantes, annuaire.
- **Mesurer l'impact métier** de chaque coupure : la cellule Continuité indique ce que chaque mesure arrête.
- **Tracer** : chaque action est horodatée dans la main courante avec son auteur.

2. Échéances à surveiller

Échéance	Objet	Ce qu'il faut avoir fait	Statut
J3 11h00	Ultimatum SIROCCO : publication des données	Position de la Direction sur la rançon ; clients concernés informés avant publication	Bloqué (Direction)
72 h après la demande (J2 15:01)	Éléments demandés par l'Autorité	Nature, périmètre, catégories de données, mesures engagées	En cours (notification initiale faite)
48 h (police d'assurance)	Déclaration à l'assureur cyber	Déclaration a minima puis compléments	Fait (couverture confirmée à 15:42)
24 h après J1 14:12	Réponse à la Chérifienne des Mines	Explication écrite et délai de rétablissement	Fait (réponse prudente notée à 15:03)
Date de paie du mois	Versement des salaires	Reconduction de la paie M-1 lancée avec la DRH	À faire

3. Indicateurs de compromission à bloquer

Type	Indicateur	Source	Action
IP (C2)	45.137.184.62:443	A-01, A-09	Blocage entrant et sortant sur tous les pare-feu
IP (VPN)	196.200.114.41 · 102.118.53.17	A-02	Blocage et recherche dans tous les journaux
Domaines	atlasgrid-it.info · atlasgrid-finance.co	A-11, A-23	Blocage DNS, messagerie et proxy ; purge des courriels reçus
Compte	svc_oasisnet	A-02, A-04, A-05, A-09	Désactivation immédiate
Compte	admin_local	A-01	Désactivation ou changement de mot de passe sur tous les postes
Fichier	C:\Windows\svchost32.exe (SHA256 3f9a4b1e...e0c71e)	A-01	Blocage par l'EDR et recherche sur tout le parc
Règle pare-feu	OUT-TEMP-443	A-09	Export puis suppression
Extension / note	.mirage · LISEZMOI_MIRAGE.txt	A-04, A-13	Détection de tout nouveau fichier chiffré

4. Phase 1 — Containment immédiat (H0 à H+2)

N°	Action	Qui	Impact métier (Continuité)	Statut
1	Maintenir FIN-112 isolé du réseau, sous tension, en attente de capture mémoire.	SOC / Forensic	Un poste de la direction financière indisponible.	Fait
2	Exporter puis supprimer la règle OUT-TEMP-443 ; bloquer les IP de l'attaquant.	SOC	Aucun.	À confirmer
3	Désactiver svc_oasisnet et suspendre tous les accès VPN prestataires.	DSI, sur décision Direction	Infogérance OasisNet arrêtée : interventions sur site, accompagnées.	À confirmer
4	Isoler du réseau les 23 serveurs chiffrés, sans les éteindre.	DSI	Aucun supplémentaire : déjà inutilisables.	À confirmer
5	Couper tout lien entre le SI et l'OT (dont agent SCCM) ; conduite locale renforcée.	Équipe OT	Pas d'impact sur la production si l'OT est sain.	En cours
6	Déconnecter VBR-01 et BKP-01/02 ; mettre les bandes LTO-9 sous clé.	Continuité / DSI	Plus aucune sauvegarde automatique jusqu'à la reprise.	À confirmer
7	Bloquer atlasgrid-it.info et atlasgrid-finance.co ; réinitialiser le compte du salarié hameçonné.	SOC	Aucun.	À confirmer

5. Phase 2 — Couper l'attaquant de l'intérieur (H+2 à H+24)

N°	Action	Qui	Impact métier (Continuité)	Statut
8	Rechercher sur tout le parc : connexions vers 45.137.184.62, présence de <code>svhost32.exe</code> , autres règles pare-feu récentes.	SOC	Aucun.	En cours
9	Réinitialiser les mots de passe de tous les comptes à privilèges et de service ; révoquer les sessions.	DSI	Reconnexion nécessaire pour administrateurs et applications.	À faire
10	Bloquer RDP et SMB entre postes de travail (mouvement latéral).	DSI	Partages entre postes indisponibles.	À faire
11	Activer la protection anti-altération de l'EDR et lancer une analyse complète.	SOC	Ralentissements temporaires.	À faire
12	Surveillance renforcée de DC-02 et de MSG-01.	SOC	Aucun.	En cours
13	Ne pas restaurer DC-01 ni repartir de DC-02 : annuaire à reconstruire à neuf.	DSI / Forensic	Authentification dégradée jusqu'à la reconstruction.	À faire
14	Désactiver le compte de l'ancien DSI <code>a.elomrani</code> ; revue des comptes d'anciens salariés.	DSI / RH	Aucun.	À faire
15	Surveiller la passerelle IT/OT et appliquer le critère de coupure (section 10).	Équipe OT / SOC	Aucun tant que rien n'est franchi.	En cours

6. Preuves à préserver avant toute action

- Journaux VPN FortiGate (A-02) et pare-feu, y compris la configuration de OUT-TEMP-443 (A-09).
- Historique Veeam et configuration de la politique de rétention (A-05).
- Mémoire vive et disque de FIN-112 ; échantillon de `svhost32.exe`.
- Une copie des notes de rançon et métadonnées NTFS de FILER-RBT-02 (A-04).
- En-têtes du courriel d'hameçonnage (A-11).
- Ces éléments sont exigés par l'assureur cyber et utiles à une éventuelle plainte.

7. Pièces reçues et qualifiées

Pièce	Objet	Verdict	Ce qu'elle établit
A-01	Journal EDR, FIN-112	Preuve	MIRAGE exécuté, EDR désactivé par <code>admin_local</code>
A-02	Journal VPN	Preuve	<code>svc_oasisnet</code> la nuit, hors pays, sans MFA, ≈12,5 Go sortis
A-04	Fiche forensic de la note de rançon	Preuve	Horodatage falsifié ; propriétaire <code>svc_oasisnet</code>
A-05	Journal des sauvegardes Veeam	Preuve	Rétention modifiée à J-3, sauvegardes ignorées, copies supprimées
A-07	Site de fuite SIROCCO	Preuve (à confirmer)	Extrait de données clients crédible ; 300 Go non corroborés
A-09	Journal du pare-feu	Preuve	Règle OUT-TEMP-443 et canal de commande vers 45.137.184.62

Pièce	Objet	Verdict	Ce qu'elle établit
A-11	Courriel d'hameçonnage	Preuve	Domaine sosie, SPF/DMARC en échec ; lien avec l'intrusion non démontré
A-13	Inventaire SCCM	Preuve	23/40 serveurs chiffrés
A-14	Badgeuse DATACENTER-1	Fausse piste	Horodatages non fiables, stagiaire en congé
A-15	Compte d'ancien DSI	À confirmer	Export à analyser ; compte désactivé par précaution
A-16	Pic de trafic site public	Fausse piste	Effet d'un article de presse, pas un DDoS
A-20	Vrai courriel de migration	Fausse piste (FP-8)	Courriel légitime de la DSI
A-23	Fraude au président	Preuve (fraude distincte)	Tentative de virement de 480 000 MAD, sans lien avec MIRAGE
A-26	Connexion depuis l'étranger	Fausse piste	Directeur commercial en déplacement, MFA validé
A-40	Ticket ransomware OasisNet	Fausse piste	Autre rançongiciel, autre client
A-41	« Souris qui bouge seule »	Fausse piste	Assistance à distance légitime (ticket HELP-3391)
—	Clé USB du parking	Fausse piste (FP-7)	Leurre jamais branché
—	Revendication DarkAtlas	Fausse piste (FP-3)	Groupe opportuniste
—	Rapport de l'équipe de nuit	Preuve	23 serveurs, chiffrement vers 03h15

8. Registre des décisions

N°	Heure	Décision	Choix	Justification	Statut
D1	J1 14:30	Poste patient zéro FIN-112	Isoler du réseau, laisser sous tension	Stopper la propagation en préservant la mémoire vive ; validé par le Forensic (15:05)	Fait
D2	J2 11:25	Couper ou maintenir les serveurs encore en service	À reporter tel que choisi dans l'application	Voir section 9 ; le RSSI (14:59) juge le choix tenable sous condition de coupure immédiate si la passerelle OT est approchée	À confirmer
D3	J2 15:05	Notifier l'Autorité	Notifier maintenant, en transparence	Obligation réglementaire ; promptitude valorisée par l'Autorité (15:42)	Fait
D4	J2	Communication presse	Réponse factuelle à Maghreb Éco	Article équilibré (15:01), apaisement en interne	Fait
D5	Avant J3 11h00	Payer ou non la rançon	Décision de la Direction	La Continuité apporte les faits : reprise possible depuis LTO-9 ; le paiement ne garantit rien	Bloqué

9. Décision : couper ou maintenir

La propagation continue et de nouveaux partages sont touchés. Décision proposée par la cellule Continuité : **tout couper et isoler du réseau.** (*À ajuster si le choix enregistré dans l'application est différent.*)

- **Pourquoi** : l'attaquant dispose de comptes à privilèges ; tant qu'on ne sait pas par où il passe, isoler seulement certains segments risque de laisser un chemin ouvert. Chaque heure de propagation coûte des serveurs encore sains.
- **Coût métier** : limité, car l'essentiel de l'activité est déjà en mode dégradé (paie, facturation, ERP chiffrés). Les services encore actifs (messagerie partielle, authentification) sont remplacés par le canal hors bande et les procédures papier.
- **Ce qui continue** : la production d'énergie (OT isolé et non dépendant du SI) et le site public, hébergé hors domaine, qui reste le canal d'information vers l'extérieur.
- **Option rejetée** : « maintenir coûte que coûte » laisserait le chiffrement atteindre les derniers serveurs sains.

10. Passerelle IT/OT : critère de coupure

Le RSSI juge tenable de ne pas arrêter un service essentiel tant que rien n'est franchi, mais rappelle que si l'attaquant atteint la passerelle vers le réseau industriel, l'enjeu devient la sûreté physique.

- **Surveillance continue** de la passerelle IT/OT et de tout flux entre les deux réseaux.
- **Critère de coupure immédiate**, sans nouvelle délibération : tout flux, toute connexion ou tout compte suspect détecté sur la passerelle ou côté OT.
- **Responsable désigné** du « bouton de coupure », joignable en permanence, avec un suppléant.
- **Conduite locale** des installations prête à être activée par les opérateurs.

11. Fuite de données : ce que le containment ne couvre pas

Le containment arrête l'attaque en cours, mais ne peut pas récupérer les données déjà sorties. L'exfiltration est établie (A-02, A-07) ; son volume réel reste à confirmer.

- **Obligations remplies** : l'Autorité a été notifiée dans les délais et a accusé réception ; l'assureur confirme la couverture.
- **Loi 09-08** : si les données publiées contiennent des données personnelles (contacts clients), information de la CNDP et évaluation de l'information des personnes concernées.
- **Clients concernés** : information directe des clients figurant dans l'extrait, en priorité la Chérifienne des Mines, avant toute publication par SIROCCO.
- **Surveillance du site de fuite** en lecture seule par le CSIRT, jusqu'à l'échéance annoncée (J3 11h00).
- **Rançon** : décision de la Direction. Le paiement ne garantit ni la suppression des données ni la non-publication ; la reprise peut se faire sans payer à partir des bandes LTO-9.

12. Continuité pendant le containment (modes dégradés)

N°	Action	Porteur	Tenable jusqu'à	Statut
P1	Déclencher officiellement le PCA	Direction	—	À confirmer
P2	Conduite locale renforcée du réseau électrique, consignes papier	Exploitation	Tant que l'OT est sain	En cours
P3	Suspension des émissions de factures ; facturation manuelle des grands comptes prioritaires	Direction financière	48 h puis manuel	À faire
P4	Bons de commande papier numérotés ; inventaire manuel des pièces critiques	Achats	3 à 5 jours	À faire

N°	Action	Porteur	Tenable jusqu'à	Statut
P5	Reconduction de la paie M-1 via la banque	DRH	Date de paie	À faire
P6	Canal de communication hors bande (mobiles, annuaire imprimé)	Continuité	Immédiat	À confirmer
P7	Double validation de tout nouveau bénéficiaire de virement (suite A-23)	Direction financière	Permanent	À faire

13. Préparation de la reprise

N°	Action	Porteur	Condition	Statut
R1	Vérifier la date et l'intégrité de la dernière bande LTO-9	Continuité	Demande à Yassine	À faire
R2	Préparer un environnement de reconstruction isolé	DSI	Après containment	À faire
R3	Reconstruire l'annuaire à neuf (pas depuis DC-02)	DSI	Feu vert Forensic	À faire
R4	Restaurer messagerie et téléphonie	DSI	Annuaire sain	À faire
R5	Restaurer ERP, facturation, puis portail client	DSI / Finance	Données vérifiées	À faire
R6	Restaurer fichiers et paie	DSI / DRH	Selon échéance de paie	À faire
R7	Rétablir l'accès OasisNet avec MFA et bastion	DSI / Direction	Explications écrites d'OasisNet	Bloqué

14. Communication et obligations

N°	Action	Porteur	Remarque	Statut
M1	Notification à l'Autorité	Risque / Conformité	Accusé de réception J2 15:42	Fait
M2	Compléments à l'Autorité sous 72 h	Risque / Conformité	Nature, périmètre, données, mesures	En cours
M3	Déclaration à l'assureur cyber	Risque / Conformité	Couverture confirmée	Fait
M4	Réponse à la Chérifienne des Mines	Communication	Réponse prudente, honnête	Fait
M5	Information des clients présents dans l'extrait de fuite (A-07)	Communication	Avant J3 11h00	À faire
M6	Évaluer l'information de la CNDP (loi 09-08)	Risque / Conformité	Si données personnelles confirmées	À faire
M7	Demande écrite formelle à OasisNet (usage de svc_oasisnet, incident de supervision)	Continuité	Réponses toujours évasives	En cours
M8	Consignes aux salariés sur les modes dégradés	Communication	Interne apaisé (15:01)	À confirmer
M9	Remercier le salarié ayant signalé la fraude au président	Communication	Bon réflexe à valoriser	À faire

15. Critères de fin du containment

Critère	Vérification
Plus aucune communication vers les IP de l'attaquant	Aucune session pendant au moins 48 h (pare-feu).
Plus aucun nouveau fichier chiffré	Aucune nouvelle extension .mirage (EDR, serveurs de fichiers).
Plus aucune connexion suspecte	Aucune authentification anormale (heure, pays, compte désactivé).
OT confirmé isolé et sain	Contrôle par l'équipe OT, aucun flux avec le SI.
Preuves préservées	Validation écrite du Forensic.

16. Main courante

Heure	Source	Événement / action
Jour 1 — Signaux faibles		
10:02	Direction (PDG)	Prise de poste ; cartographie demandée pour 12h00
10:07	Direction (PDG)	Dossier de prise de poste transmis
10:17	SOC	Campagne d'hameçonnage vers la direction financière
10:32	Support	Vague de tickets dans plusieurs services
10:42	Cellule	A-11 qualifiée preuve
10:52	Cellule	A-01 qualifiée preuve
11:12	OasisNet	Message évasif sur une maintenance « mal terminée »
11:17	Salarié DF	Déclare avoir saisi son mot de passe
11:52	DSI	Parle d'un « incident mineur »
13:27	Cellule	A-02 qualifiée preuve (compte svc_oasisnet)
13:47	Direction financière	Fichiers .mirage sur le partage comptable
14:02	SOC	Clé USB écartée (FP-7)
14:12	Chérifienne des Mines	Réclamation : portail inaccessible, réponse exigée sous 24 h
~14:30	Cellule	Décision D1 : FIN-112 isolé sous tension
14:57	Cellule	Cartographie déposée (retard sur 12h00)
15:05	Forensic	Isolement de FIN-112 validé
15:12	DSI	Courriel de migration confirmé légitime (FP-8)
15:22	Cellule	A-05 qualifiée preuve (sauvegardes)
15:28	Veeam	BKP-01 et BKP-02 injoignables
Jour 2 — L'ultimatum		
10:01	SIROCCO	Note de rançon : 20 BTC sous 48 h
10:11	Forensic	A-04 : horodatage falsifié de la note
10:14	SOC	A-13 : 23/40 serveurs chiffrés
10:18	SOC	A-09 : règle pare-feu et canal C2
10:21	Équipe de nuit	Rapport : chiffrement vers 03h15
10:56 – 11:24	SOC	A-16, A-15, A-41, A-14, A-23, A-40, A-26 reçues et qualifiées
11:06	OasisNet	« Anomalie de supervision », toujours évasif
11:16	Salarié DF	Signale un ordre de virement suspect, rien exécuté
~11:25	Cellule	Décision D2 : couper ou maintenir
14:59	RSSI	Choix tenable, garder le doigt sur le bouton de coupure OT
15:01	Autorité	Demande d'éléments sous 72 h

Heure	Source	Événement / action
15:01	Presse / interne	Article équilibré ; apaisement des équipes
15:03	Chérifienne / assureur	Réponse prudente notée ; posture validée par l'assureur
~15:05	Cellule	Décision D3 : notification à l'Autorité
15:26	Forensic	DarkAtlas écarté (FP-3)
15:31	Cellule	A-07 qualifiée preuve (à confirmer)
Fin J2	SIROCCO	Publication annoncée pour J3 11h00
15:42	Autorité / assureur	Notification reçue ; couverture confirmée

17. Points ouverts

- Choix exact retenu pour la décision D2 (couper ou maintenir) à reporter dans ce document.
- Date et intégrité de la dernière bande LTO-9.
- Volume et nature réels des données exfiltrées (12,5 Go observés, 300 Go annoncés).
- Analyse de l'export A-15 (compte a.elomrani) : IP identiques à celles de l'attaquant ?
- Étanchéité réelle du réseau OT et rôle de la passerelle IT/OT.
- Explications d'OasisNet sur l'usage de son compte de service.

18. Conclusion

Au soir du deuxième jour, l'attaquant est coupé de ses accès connus (compte prestataire, règle pare-feu, canal de commande), le réseau industriel est protégé par un critère de coupure clair, et les obligations de notification sont respectées. Les fausses pistes ont été écartées sur des éléments vérifiables.

Le risque principal n'est plus technique mais lié aux données : SIROCCO détient une partie de nos données clients et menace de les publier. La suite relève de l'éradication (reconstruction de l'annuaire, réinstallation des serveurs), de la reprise selon le PRA à partir des bandes LTO-9, et de la gestion de la fuite avec la Direction, la Communication et Risque/Conformité. L'attaquant peut tenter de revenir par un autre accès : la vigilance reste maximale.